ADVANCED CYBERSECURITY RISK QUANTIFICATION ASSIGNMENT

SecureBank Financial | SecureMobile Banking Platform

Student Name: Joan Kemboi

Registration Number: C11/26/CGRCE/17594

Programme: GRC Engineering Cohort 11

Course: GRC103 – Information Security Governance

Executive Dashboard

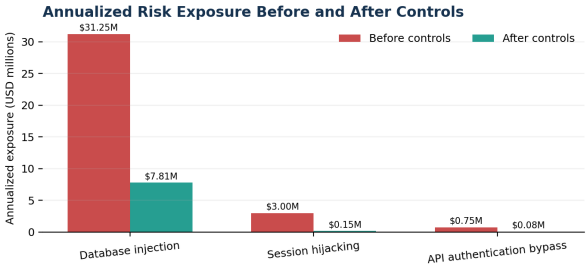
SecureBank Financial | SecureMobile mobile banking platform

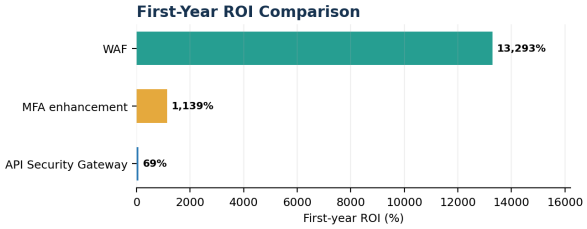
Current annualized risk exposure	**$35.00M**	Estimated residual exposure after all controls	**$8.04M**
Annual risk reduction	**$26.96M**	Overall exposure reduction	**77.0%**
Initial capital investment	**$700K**	First-year cost including maintenance	**$805K**
Portfolio first-year ROI	**3,249.38%**	First-year net financial benefit	**$26,157,500**

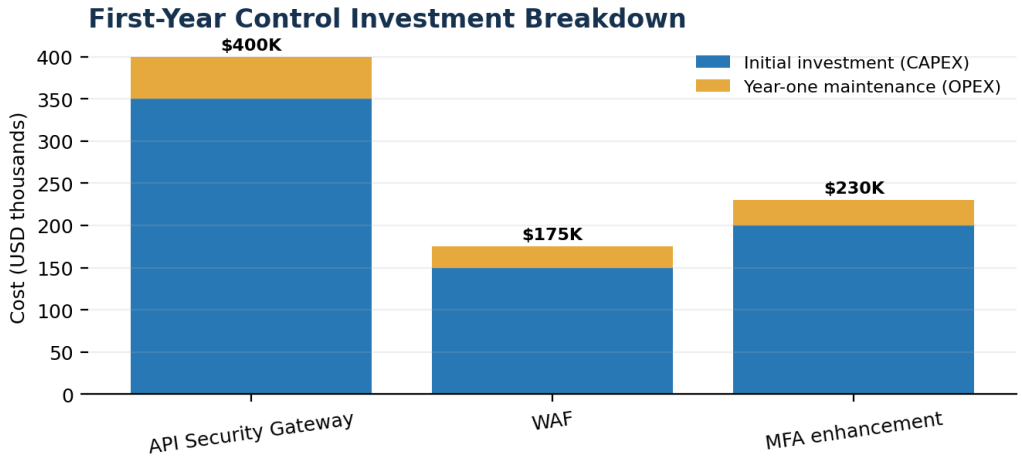
Top three risks

Priority	Finding	Current ALE	Proposed control
Critical (P1)	Database injection	$31.25M	WAF - $150K
High (P2)	Session hijacking	$3.00M	MFA - $200K
Medium (P3)	API authentication bypass	$0.75M	API gateway - $350K

Risk and investment outlook







The investment breakdown includes first-year maintenance. Risk reduction figures are annualised estimates, not guaranteed cash savings.

Recommendation: implement the WAF first, strengthen account and session protection through MFA second, and complete the API gateway deployment as the longer-term control.

1. Introduction

This assignment evaluates the cybersecurity risks identified during a penetration test and vulnerability assessment of SecureBank Financial's SecureMobile banking application. The assessment translates the technical findings into estimated financial exposure, compares proposed security controls and presents recommendations for management decision-making.

The platform supports 500,000 active customers, an average transaction value of $2,500 and approximately 50,000 transactions each day. These figures describe the scale and business importance of the platform. The calculations below use the specific loss assumptions supplied for each vulnerability; the transaction figures are not multiplied into the loss estimates because the lab does not provide a formula linking them to the stated single-incident losses.

The three findings are an API authentication bypass affecting transaction processing, a database injection vulnerability affecting customer records, and session hijacking affecting active user sessions.

2. Risk Exposure Calculation

2.1 Finding 1: API Authentication Bypass

The API authentication bypass affects the transaction processing system. If exploited, it could allow unauthorised fund transfers. The lab estimates a maximum single-incident loss of $5,000,000 and an exploit probability of 15%.

The SLE is therefore $5,000,000. The ARO is 0.15. Multiplying these values gives an ALE of $750,000 per year.

Calculation: $5,000,000 × 0.15 = $750,000.

2.2 Finding 2: Database Injection Vulnerability

The database injection vulnerability affects the customer database and could expose personal and financial information belonging to 500,000 customer profiles. The lab provides an estimated regulatory and notification cost of $250 per record and an exploit probability of 25%.

The SLE is calculated by multiplying the number of records at risk by the estimated cost per record: 500,000 × $250 = $125,000,000. Applying the ARO of 0.25 produces an ALE of $31,250,000 per year.

Calculation: (500,000 × $250) × 0.25 = $31,250,000.

2.3 Finding 3: Session Hijacking

The session hijacking vulnerability affects active user sessions and could result in account takeover. The dataset identifies 5,000 simultaneous sessions at risk, an average loss of $1,500 per account and an exploit probability of 40%.

The SLE is 5,000 × $1,500, which equals $7,500,000. Applying the ARO of 0.40 produces an ALE of $3,000,000 per year.

Calculation: (5,000 × $1,500) × 0.40 = $3,000,000.

2.4 Risk Prioritisation Matrix

The findings are prioritised by considering both their potential single-incident loss and their annual occurrence rate. Database injection is ranked Critical because it has the greatest financial impact. Session hijacking is ranked High because it has the highest occurrence probability and a material loss per incident. API authentication bypass is ranked Medium because its estimated annual exposure is lower than the other two findings, although unauthorised fund transfers remain a serious concern.

Vulnerability	Affected system	SLE	ARO	ALE	Priority
Database injection	Customer database	$125,000,000	25%	$31,250,000	Critical (P1)
Session hijacking	User sessions	$7,500,000	40%	$3,000,000	High (P2)
API authentication bypass	Transaction processing	$5,000,000	15%	$750,000	Medium (P3)
Total				$35,000,000	

2.5 Risk Visualisations

The ALE bar chart compares the estimated annual financial exposure of the three findings. Database injection dominates the comparison at $31.25 million, followed by session hijacking at $3 million and API authentication bypass at $750,000.

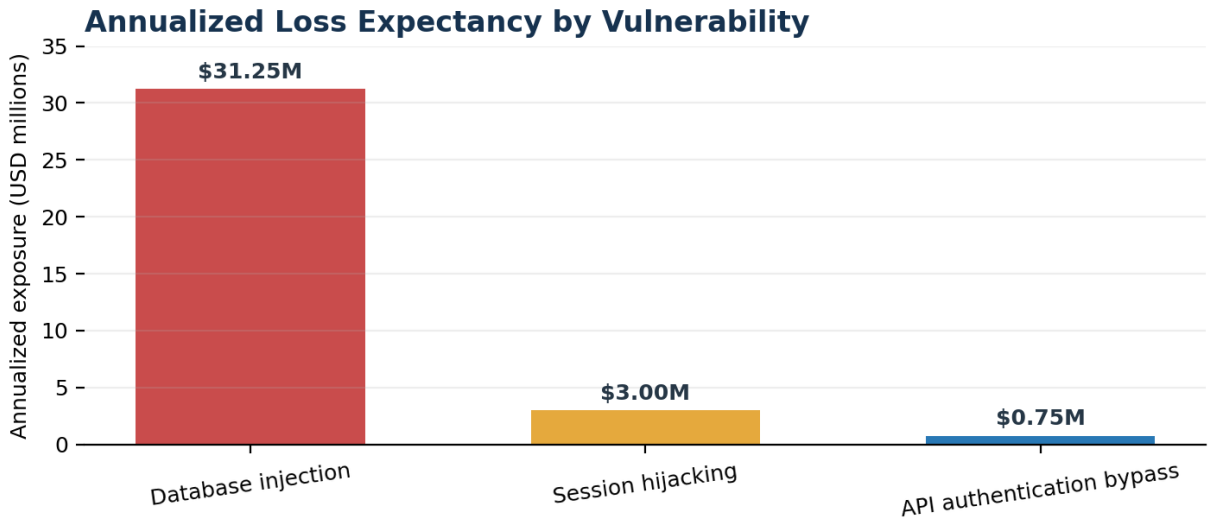


Figure 1. Annualized Loss Expectancy for the three identified vulnerabilities.

The pie chart shows each finding's share of the total $35 million annualised exposure. Database injection accounts for approximately 89.3% of the total, session hijacking accounts for approximately 8.6%, and API authentication bypass accounts for approximately 2.1%.

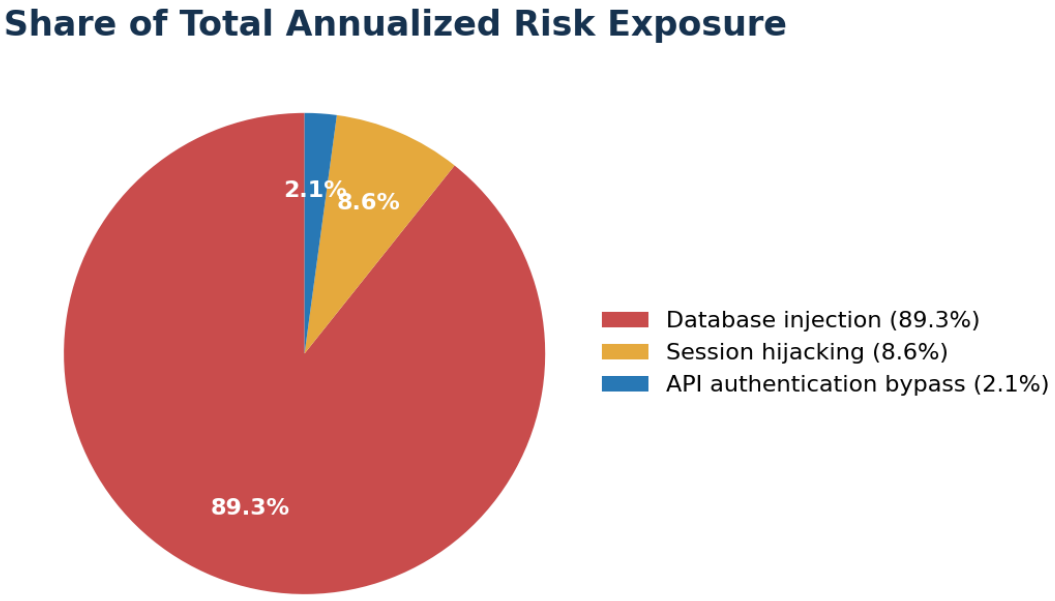


Figure 2. Proportion of total annualised risk exposure represented by each vulnerability.

The lab asks for a heat map using probability and impact but does not prescribe category boundaries. For this visualisation, low likelihood is below 15%, medium likelihood is 15% to 30% inclusive, and high likelihood is above 30%; low impact is below $1 million, medium impact is $1 million to $10 million inclusive, and high impact is above $10 million. Impact is measured using SLE. To assign a combined rating, likelihood and impact tiers are each scored from 1 to 3 and multiplied: scores of 1-2 are Low, 3-4 are Medium, and 6-9 are High.

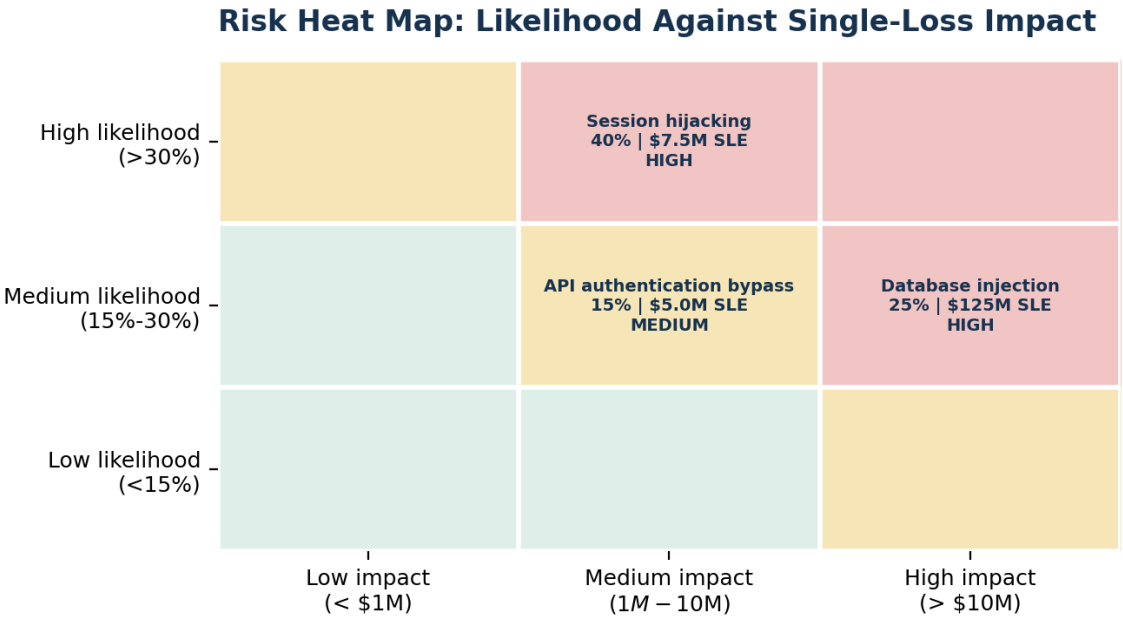


Figure 3. Risk heat map using the stated likelihood and single-loss impact thresholds.

Using this method, database injection falls in the medium-likelihood/high-impact cell and receives a High heat-map rating; session hijacking falls in the high-likelihood/medium-impact cell and also receives a High rating; API authentication bypass falls in the medium-likelihood/medium-impact cell and receives a Medium rating. The heat map is a qualitative presentation of the numerical inputs; the P1, P2 and P3 designations remain the prioritisation judgements used in this report.

3. Security Control Evaluation

Each control is matched to the vulnerability it is intended to reduce. The expected annual risk reduction is calculated by applying the control effectiveness percentage to the current ALE. The residual ALE is the portion of current exposure expected to remain after the control is implemented.

3.1 Advanced API Security Gateway

The Advanced API Security Gateway is intended to reduce the API authentication bypass risk by 90%. The initial implementation cost is $350,000 and annual maintenance is $50,000. Applying the effectiveness estimate to the current ALE of $750,000 gives a residual ALE of $75,000. The resulting annual risk reduction benefit is $675,000.

Residual ALE: $750,000 × (1 − 0.90) = $75,000. Risk reduction: $750,000 − $75,000 = $675,000 per year.

ROI on initial capital: ($675,000 − $350,000) ÷ $350,000 × 100 = 92.86%. First-year ROI including maintenance: ($675,000 − $400,000) ÷ $400,000 × 100 = 68.75%. The first-year cost is $400,000, comprising $350,000 implementation and $50,000 maintenance.

Payback period: $350,000 ÷ ($675,000 − $50,000) = 0.56 years, or approximately 6.7 months.

3.2 Web Application Firewall (WAF)

The Web Application Firewall is intended to reduce the database injection risk by 75%. The initial implementation cost is $150,000 and annual maintenance is $25,000. Applying the control effectiveness to the current ALE of $31,250,000 gives a residual ALE of $7,812,500 and an annual risk reduction benefit of $23,437,500.

Residual ALE: $31,250,000 × (1 − 0.75) = $7,812,500. Risk reduction: $31,250,000 − $7,812,500 = $23,437,500 per year.

ROI on initial capital: ($23,437,500 − $150,000) ÷ $150,000 × 100 = 15,525.00%. First-year ROI including maintenance: ($23,437,500 − $175,000) ÷ $175,000 × 100 = 13,292.86%. The first-year cost is $175,000, comprising $150,000 implementation and $25,000 maintenance.

Payback period: $150,000 ÷ ($23,437,500 − $25,000) = 0.0064 years, or approximately 2.3 days.

3.3 Multi-Factor Authentication Enhancement

The MFA enhancement is intended to reduce session hijacking and account takeover risk by 95%. The initial implementation cost is $200,000 and annual maintenance is $30,000. Applying the control effectiveness to the current ALE of $3,000,000 gives a residual ALE of $150,000 and an annual risk reduction benefit of $2,850,000.

Residual ALE: $3,000,000 × (1 − 0.95) = $150,000. Risk reduction: $3,000,000 − $150,000 = $2,850,000 per year.

ROI on initial capital: ($2,850,000 − $200,000) ÷ $200,000 × 100 = 1,325.00%.

First-year ROI including maintenance: ($2,850,000 − $230,000) ÷ $230,000 × 100 = 1,139.13%.

The first-year cost is $230,000, comprising $200,000 implementation and $30,000 maintenance.

Payback period: $200,000 ÷ ($2,850,000 − $30,000) = 0.0709 years, or approximately 25.9 days.

3.4 Control Cost-Benefit Analysis

Control	Initial cost	Annual maintenance	Risk reduction / year	Residual ALE	Year-one ROI	Payback
API Security Gateway	$350,000	$50,000	$675,000	$75,000	68.75%	6.7 months
WAF	$150,000	$25,000	$23,437,500	$7,812,500	13,292.86%	2.3 days
MFA enhancement	$200,000	$30,000	$2,850,000	$150,000	1,139.13%	25.9 days
Portfolio	$700,000	$105,000	$26,962,500	$8,037,500	3,249.38%	See note below

The ROI results are shown on both a capital-only basis and a first-year cost basis so the effect of maintenance expenditure is clear.

Control	ROI using initial capital only	First-year ROI including maintenance
API Security Gateway	92.86%	68.75%
WAF	15,525.00%	13,292.86%
MFA enhancement	1,325.00%	1,139.13%
Full portfolio	3,751.79%	3,249.38%

For the combined portfolio, the first-year cost is $805,000 ($700,000 capital expenditure plus $105,000 maintenance). The first-year net financial benefit is $26,157,500, calculated as $26,962,500 less $805,000. The portfolio first-year ROI is therefore 3,249.38%; the capital-only ROI is 3,751.79%. A single portfolio payback period is not presented because the three controls are deployed at different points in the proposed implementation schedule.

4. Control Selection Analysis and Required Visualisations

4.1 Initial Cost Compared with Control Effectiveness

The scatter plot compares each control’s initial implementation cost with its expected effectiveness. MFA has the highest stated effectiveness at 95%, while the API Security Gateway has the highest initial cost at $350,000. The WAF has the lowest initial cost at $150,000 and is expected to reduce its target risk by 75%. Effectiveness alone does not determine selection; the financial exposure addressed by each control is also important.

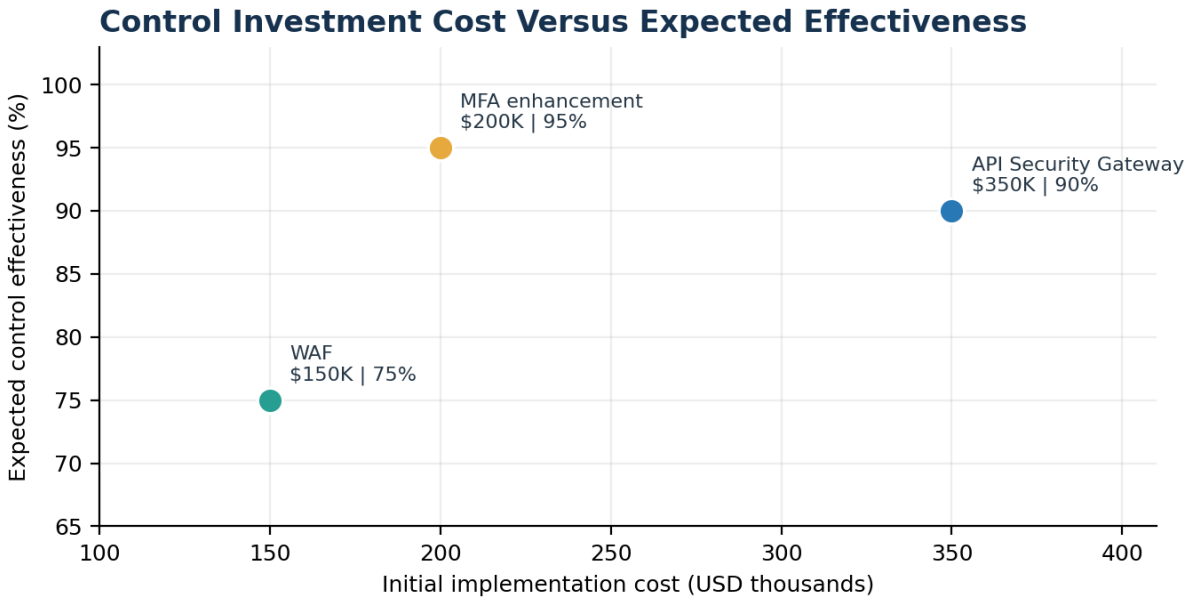


Figure 4. Initial capital investment plotted against expected control effectiveness.

4.2 Return on Investment Comparison

The ROI comparison uses each control's first-year total cost, including maintenance. The WAF produces the highest calculated first-year ROI because it addresses the largest current ALE. MFA ranks second, while the API Security Gateway has the lowest ROI of the three, although its expected benefit still exceeds its first-year cost.

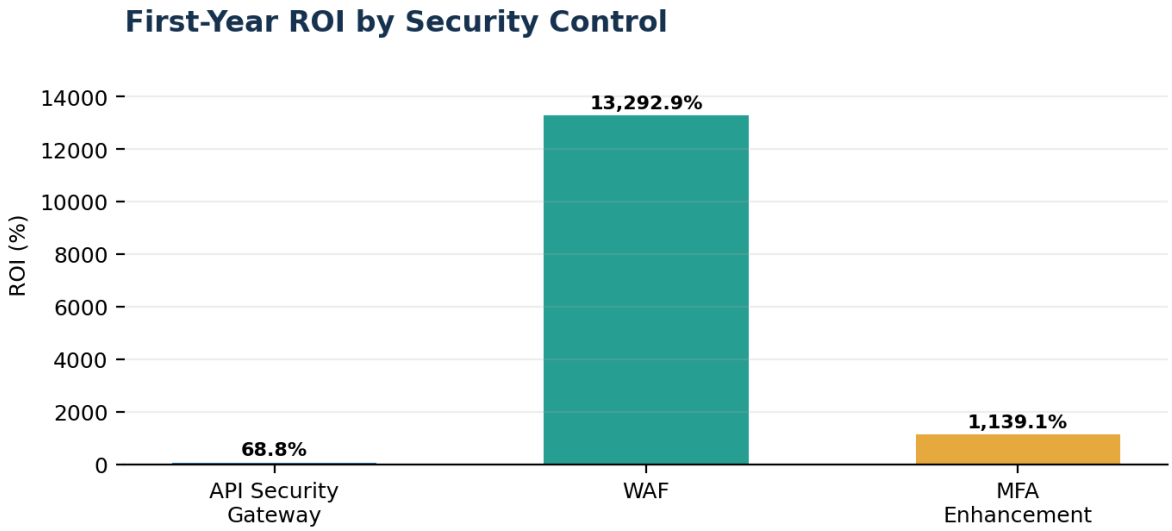


Figure 5. First-year ROI by control, calculated using initial cost plus first-year maintenance.

4.3 Projected Risk Reduction Over Time

The line graph follows the proposed sequence of implementation: WAF by Day 30, MFA by Day 90 and the API Security Gateway by Day 365. It shows cumulative annualised risk reduction at each milestone. These values represent the annualised exposure reduction expected once each control is in place; they are not cumulative cash savings actually received during the implementation period.

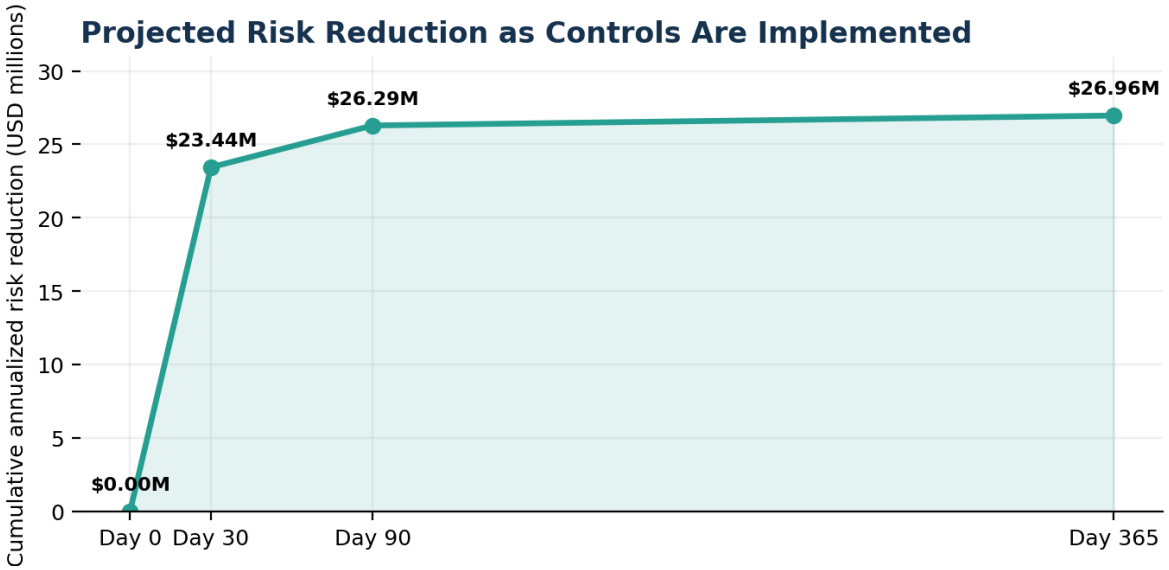


Figure 6. Projected cumulative annualised risk reduction at the implementation milestones.

5. Executive Reporting

5.1 Executive Risk Summary

SecureBank Financial's SecureMobile platform has an estimated combined annualised risk exposure of $35,000,000 across the three findings. Database injection is the leading concern, with an ALE of $31,250,000. Session hijacking contributes $3,000,000 and API authentication bypass contributes $750,000.

The proposed controls require $700,000 in initial capital expenditure and $105,000 in annual maintenance. Their combined expected annual risk reduction is $26,962,500, leaving an estimated residual ALE of $8,037,500. The resulting exposure reduction is approximately 77%. The first-year net financial benefit is estimated at $26,157,500, producing a portfolio first-year ROI of 3,249.38%.

The executive dashboard appears near the beginning of this report and summarises the top risks, control costs, risk reduction and ROI. The following figures provide the requested detailed comparisons.

5.2 Risk Exposure Before and After Controls

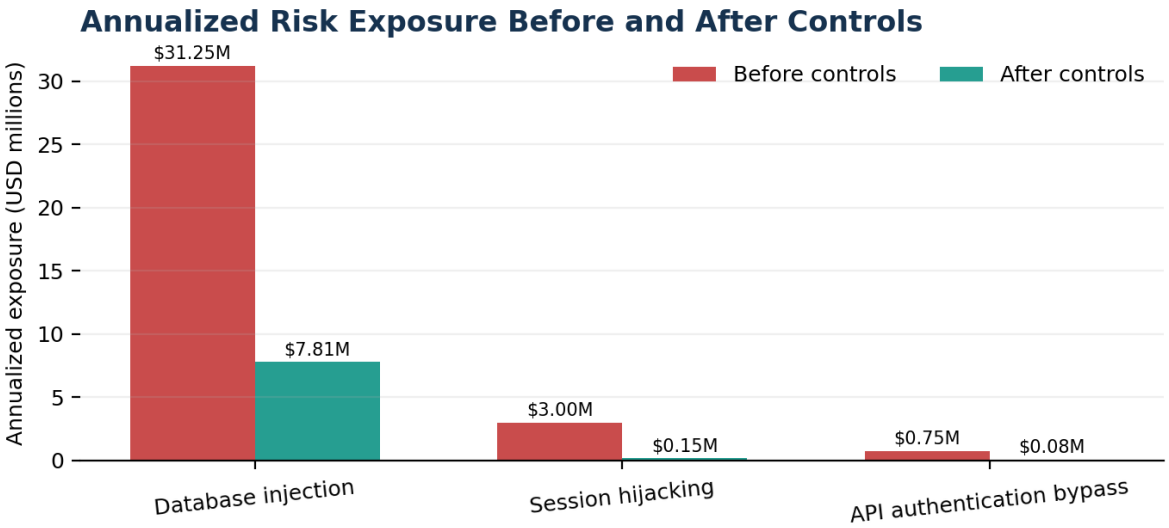


Figure 7. Comparison of current and residual ALE for each vulnerability.

5.3 Control Investment Breakdown

The stacked bar chart separates each control's initial capital expenditure from its first-year maintenance expenditure. The first-year control cost is $400,000 for the API Security Gateway, $175,000 for the WAF and $230,000 for MFA. Across the three controls, capital expenditure totals $700,000 and first-year maintenance totals $105,000.

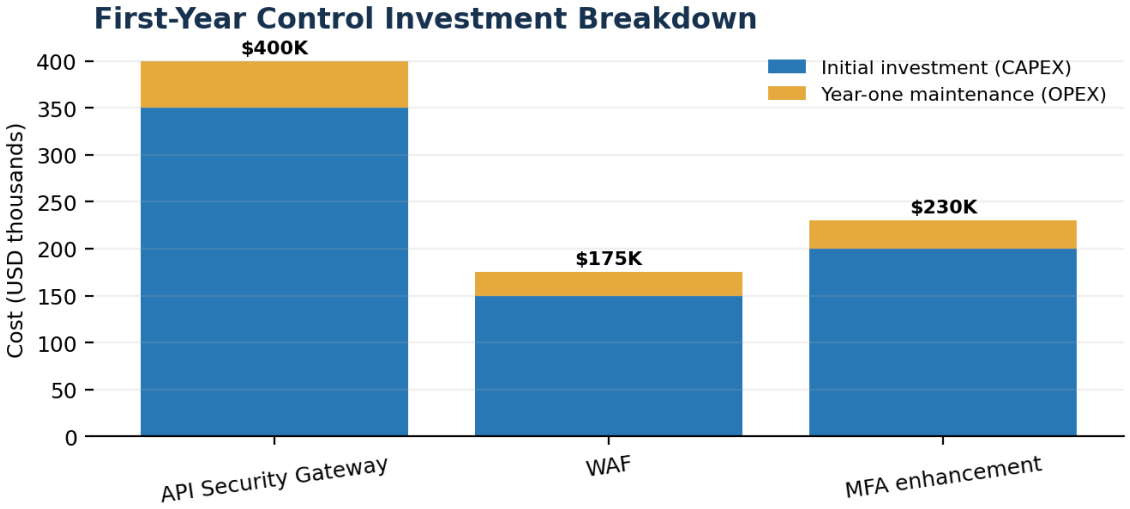


Figure 8. First-year investment split between implementation and maintenance.

5.4 ROI Comparison Across Controls

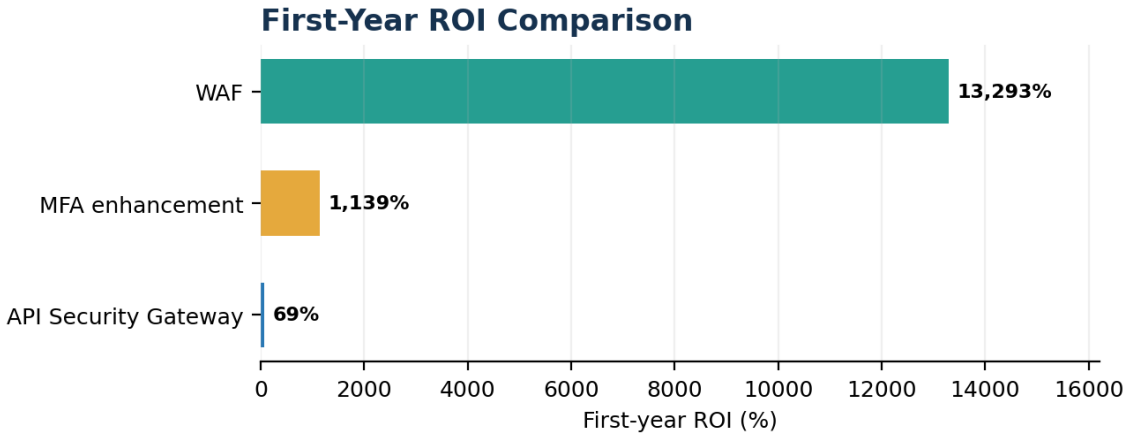


Figure 9. Horizontal comparison of first-year ROI across the three security controls.

6. Risk Treatment Timeline

The implementation plan follows the lab's three time horizons. The WAF is treated as the immediate action because database injection represents most of the current financial exposure. MFA and session hardening follow within the first 90 days. The API Security Gateway and supporting secure-development activities are scheduled as the longer-term work to be completed within one year.

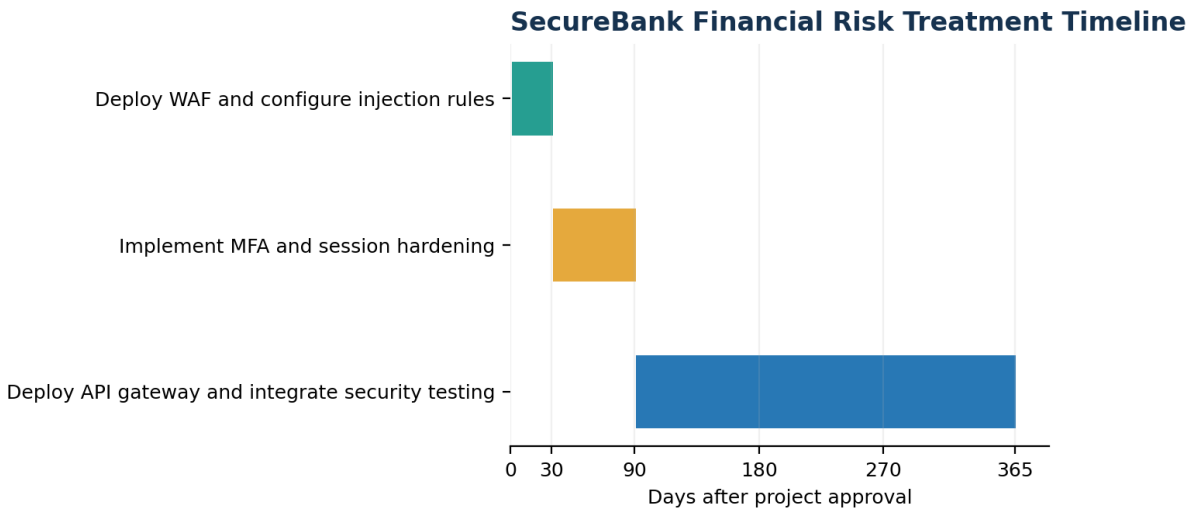


Figure 10. Gantt-style implementation schedule for the proposed risk treatment plan.

Phase	Timeline	Main activities	Initial investment	Expected additional annual risk reduction
Immediate response	Days 1-30	Deploy WAF; configure rules and virtual patching to block database injection.	$150,000	$23,437,500
Short-term controls	Days 31-90	Implement MFA; strengthen session token rotation and automatic invalidation.	$200,000	$2,850,000
Long-term strategy	Days 91-365	Deploy API Security Gateway; introduce OAuth 2.0/JWT validation and integrate SAST/DAST and automated penetration testing.	$350,000	$675,000

The cumulative annualised risk reduction is expected to reach $23,437,500 after Phase 1, $26,287,500 after Phase 2 and $26,962,500 after Phase 3. Actual delivery dates and risk reduction should be confirmed through project governance, testing and post-implementation control validation.

7. Bonus: Combined Risk-Control and Budget Optimisation Matrix

The combined matrix compares each vulnerability's current exposure with its expected residual exposure after the proposed control. It also compares the first-year control cost with the expected annual risk reduction and the resulting net first-year benefit.

Current vulnerability / ALE	Proposed control	First-year control cost	Annual risk reduction	Net first-year benefit	Residual ALE	Selection priority
$31,250,000 - Database injection	WAF	$175,000	$23,437,500	$23,262,500	$7,812,500	1 - Immediate
$3,000,000 - Session hijacking	MFA enhancement	$230,000	$2,850,000	$2,620,000	$150,000	2 - Short term
$750,000 - API authentication bypass	API Security Gateway	$400,000	$675,000	$275,000	$75,000	3 - Long term
$35,000,000 - Total	Full security package	$805,000	$26,962,500	$26,157,500	$8,037,500	Full programme

The selection priority is based on the amount of financial exposure addressed and the urgency of the vulnerability, rather than ROI alone. The WAF is the strongest immediate investment because it addresses the largest ALE. MFA follows because session hijacking has the highest stated likelihood. The API gateway remains part of the full treatment plan even though its projected financial return is lower than the other two controls.

7.1 Budget-Constrained Option

If SecureBank Financial cannot fund all three controls at once, the lab data support implementing the WAF and MFA enhancement first. Together, their initial capital cost is $350,000 and their combined first-year cost is $405,000, including maintenance. Their combined annual risk reduction is $26,287,500, or approximately 97.5% of the $26,962,500 total risk reduction available from the full control package.

This option leaves the API authentication bypass vulnerability with its current $750,000 ALE until the API gateway is implemented. It should therefore be treated as a staged funding decision rather than a complete risk treatment. The API gateway should remain on the approved roadmap, with interim monitoring and compensating safeguards maintained.

8. Conclusion and Recommendations

The assessment estimates that SecureBank Financial's SecureMobile platform is exposed to $35 million in annualised losses from the three vulnerabilities identified in the lab. Database injection is the most significant financial risk, followed by session hijacking and API authentication bypass.

The recommended approach is to deploy the WAF first, strengthen authentication and session management through MFA second, and complete the API Security Gateway deployment within the one-year treatment period. Based on the supplied effectiveness estimates, the full package is expected to reduce annualised exposure by approximately 77%, from $35 million to $8.04 million.

The CISO and CFO should review the costs, validate the assumptions and approve implementation in phases. After deployment, the organisation should test the controls, monitor security events, reassess residual risk and update the financial estimates as operational evidence becomes available. Control effectiveness should not be assumed to be perfect or permanent.